



FINANCIAL PROPOSAL FOR GRC FRAMEWORK ENGAGEMENT

*In support of the Technical Proposal: GRC Framework Implementation
aligned with ISO/IEC 27001:2022 & NIST CSF 2.0*

Abstract

This financial proposal provides a detailed cost structure for the implementation of an integrated GRC framework, aligned with ISO/IEC 27001:2022 and NIST CSF 2.0. It outlines professional service fees for risk assessment, control gap analysis, policy development, and audit readiness activities. The pricing ensures a cost-effective approach while delivering measurable compliance, governance, and risk management outcomes.

G-R-C Ops

1. Financial Executive Summary

This proposal outlines professional service fees for the design and implementation of an ISMS, cybersecurity risk assessment, ISO 27001 gap analysis, NIST CSF mapping, and audit readiness preparation over a ten months engagement.

Pricing reflects a consulting team with hands-on guidance and senior-level consultancy premiums.

Total Project Duration: 10 Months
Engagement Model: Fixed-Price Consulting Project

2. Pricing Model Assumptions

- Mid-sized organization (200–500 employees)
- 5-member consulting team
- Hybrid engagement with structured workshops
- Executive-level reporting provided in collaboration with trainers/mentors
- Standard documentation deliverables included
- No technical implementation or certification fees
- Estimated total consulting effort: 700–900 hours

3. Phase-Based Cost Allocation

Phase	Key Activities	Duration	Total (SAR)
Phase 1 – Initiation & Governance	Project kickoff, ISMS scope, governance setup, risk methodology approval	Month 1	7,475
Phase 2 – ISO 27001 Gap Assessment	Documentation review, stakeholder interviews, control maturity assessment, gap report, NIST CSF alignment	Months 2–3	12,075
Phase 3 – Enterprise Risk Assessment	Asset classification, threat & vulnerability analysis, risk scoring, risk register, risk heat map	Months 4–5	13,225
Phase 4 – Risk Treatment & Policy Framework	Risk treatment decisions, SoA development, control alignment, policy drafting	Months 6–7	14,950
Phase 5 – ISMS Documentation & Audit Readiness	ISMS compilation, KPI/KRI definition, internal audit simulation, executive readiness report	Months 8–10	21,275
Total			68,500 SAR (~18,200 USD)

- **Certification fees:** ISO 27001 Stage 1 + Stage 2 audit included (SAR 8,000).
- VAT 15% applied on consulting and certification fees.
- **Total project cost:** SAR 68,500 (~USD 18,200).

4. Payment Schedule

Milestone	Percentage	Amount (SAR / USD)
Contract Signing	40%	19,000 / 5,200
Completion of Risk Assessment Phase	30%	14,250 / 3,900
Project Completion	30%	14,250 / 3,900

Payment Terms: 15 days from invoice date

5. Included Deliverables

- ISO 27001 Gap Assessment Report
 - Enterprise Risk Register
 - Risk Heat Map
 - NIST CSF Mapping Matrix
 - Statement of Applicability (SoA)
 - Risk Treatment Plan
 - Policy Framework Pack
 - ISMS Manual
 - Internal Audit Simulation Checklist
 - Executive Readiness Report
 - Certification body fees
 - Tool licensing
-

6. Exclusions

- Technical vulnerability scanning
 - Penetration testing / red teaming
 - SOC implementation
-

7. Pricing Validity

This financial proposal is valid for **120 days** from submission.